SECUREBANK FINANCIAL

SecureMobile Cybersecurity Risk Quantification
Lab 3b: Advanced Cybersecurity Risk Quantification

Prepared by: Hilda Odein Joshua-Jack
Registration number: C11/26/CGRCE/17247
Evaluation period: Three years

1. Executive summary

The assessment identifies three material risks to SecureMobile: API authentication bypass, database injection and session hijacking. Using the supplied exploit probabilities as annual probabilities of one loss event, the model estimates current annual expected loss at $35,000,000. Database injection is the dominant exposure, contributing $31,250,000 (89.3%) of the total. Session hijacking contributes $3,000,000 and API authentication bypass contributes $750,000.

The recommended treatment is a targeted three-control package: Advanced API Security Gateway, WAF and MFA enhancement. Under the stated control mapping and effectiveness assumptions, estimated residual annual expected loss falls to $8,037,500, a reduction of $26,962,500 (77.0%). The package requires $700,000 initial investment and $105,000 annual maintenance. These figures are modelled expected-loss reductions, not guaranteed cash savings.

Decision requested: approve the control package subject to confirming that all relevant database-injection traffic traverses the WAF, completing staged testing, and establishing quarterly effectiveness reporting.

2. Scope and methodology

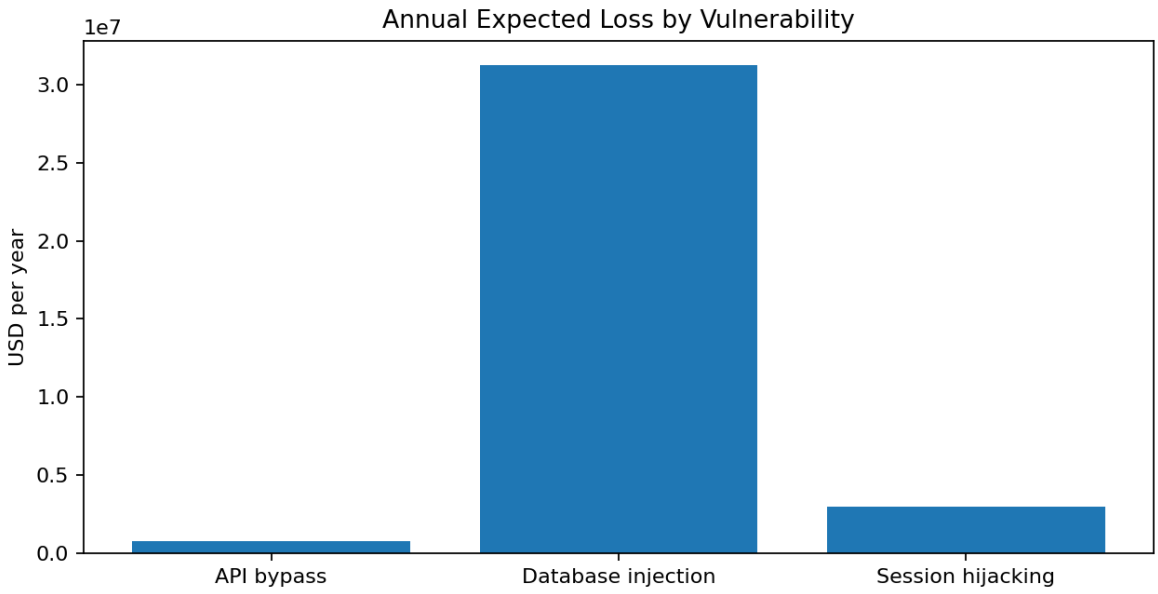
The analysis covers only the three findings and supplied system context in the practical brief. Single Loss Expectancy (SLE) estimates the financial consequence of one successful loss event. Annualised Loss Expectancy (ALE) is modelled as SLE multiplied by the supplied annual event probability. Because the brief does not specify a probability time horizon, this report explicitly interprets each probability as the chance of one loss event occurring during a one-year period.

This is a Bernoulli-style annual probability model. It is not an annual incident frequency (ARO) count and should not be interpreted as a forecast that exactly 0.15, 0.25 or 0.40 incidents will occur. If multiple incidents can occur in a year, event frequency and loss severity distributions would be needed. The workbook therefore labels the probability field clearly and uses it as the annual event probability in the ALE calculation.

3. Risk exposure calculations

Finding	SLE	Annual probability	ALE	Priority
API authentication bypass	$5,000,000	15%	$750,000	Moderate
Database injection	$125,000,000	25%	$31,250,000	Critical
Session hijacking	$7,500,000	40%	$3,000,000	High
TOTAL	$137,500,000	—	$35,000,000	—

Calculations: API SLE = $5,000,000; ALE = $5,000,000 × 15% = $750,000. Database SLE = 500,000 records × $250 = $125,000,000; ALE = $125,000,000 × 25% = $31,250,000. Session SLE = 5,000 sessions × $1,500 = $7,500,000; ALE = $7,500,000 × 40% = $3,000,000.



The database finding dominates the model because the supplied per-record cost creates a $125 million single-event exposure. The $250 per-record assumption should be validated against SecureBank's actual regulatory, notification, legal, remediation and customer-support cost basis.

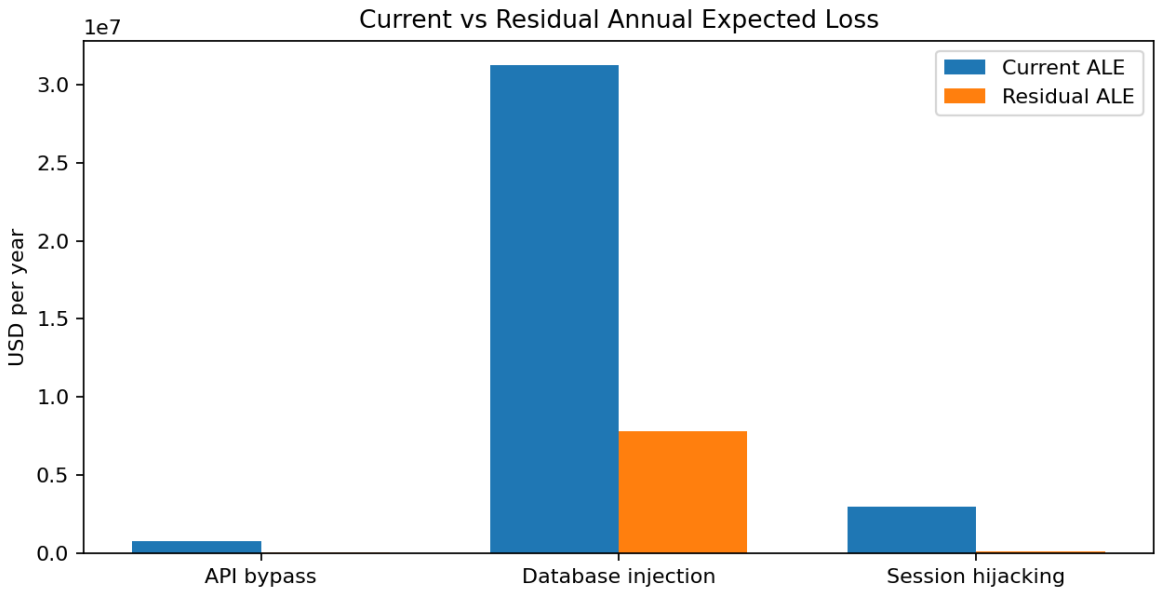
4. Control evaluation and financial justification

Control	Initial cost	Annual upkeep	Effectiveness	Annual reduction	Residual ALE	3-year ROI
API Security Gateway	$350,000	$50,000	90%	$675,000	$75,000	305%
WAF	$150,000	$25,000	75%	$23,437,500	$7,812,500	31,161%
MFA enhancement	$200,000	$30,000	95%	$2,850,000	$150,000	2,848%

Control mapping: the API gateway reduces the API authentication-bypass exposure; the WAF reduces database-injection exposure, provided the vulnerable traffic passes through it; and MFA reduces session hijacking/account-takeover exposure. Each control is applied to one distinct risk only. No control benefit is counted against multiple risks, and no overlapping percentage reductions are compounded.

For each control, annual risk reduction = current ALE × stated effectiveness. Residual ALE = current ALE − annual risk reduction. Three-year ROI = [(annual risk reduction × 3) − (initial cost + annual maintenance × 3)] ÷ [initial cost + annual maintenance × 3]. Simple payback = initial cost ÷ (annual risk reduction − annual maintenance).

Estimated simple payback is approximately 0.56 years (6.7 months) for the API gateway, 0.0064 years (about 2.3 days) for the WAF, and 0.071 years (about 25.9 days) for MFA. The unusually short WAF payback is a mathematical consequence of the very high modelled database ALE, not a promise of realised savings.



5. Combined residual risk and investment

Current portfolio ALE is $35,000,000 per year. Combined annual expected-loss reduction is $26,962,500, leaving $8,037,500 residual ALE. This represents an estimated 77.0% reduction in annual expected loss. Initial investment totals $700,000; annual maintenance totals $105,000. Over three years, total cost is $1,015,000 and modelled avoided loss is $80,887,500, giving a portfolio ROI of approximately 7,869.7%. Portfolio simple payback is approximately 9.5 days using the same undiscounted assumptions.

ROI is highly sensitive to the supplied loss and probability assumptions. It represents modelled avoided exposure rather than a guaranteed accounting return. The analysis excludes discounting, implementation delay, residual control failure, insurance, correlated events and changes in customer base or transaction volumes.

6. Prioritised recommendations

1. Treat database injection as the first financial priority. Validate the $250 per-record cost assumption, remediate the injection flaw at source through parameterised queries/input handling, and deploy WAF rules as a compensating/defence-in-depth control.

2. Strengthen session security through MFA, session-token rotation, secure cookie settings, device/risk-based monitoring and rapid revocation. The 40% supplied probability is the highest of the three.

3. Deploy the Advanced API Security Gateway with strong authentication and authorisation enforcement, rate limiting, schema validation and monitoring. The 48-hour detection estimate makes rapid detection and transaction anomaly controls important.

4. Require independent retesting and evidence before marking controls effective. Measure blocked attacks, false positives, MFA adoption, anomalous session revocations, injection test outcomes and API authorisation test pass rates.

5. Reassess risk quarterly and after material platform changes. Replace scenario probabilities with incident, threat-intelligence and control-performance data when available.

7. Phased risk treatment plan

Phase	Timing	Key actions	Evidence / outcome
Immediate	Days 1–30	Emergency API	Approved emergency

		authorisation checks; review anomalous sessions and transaction alerts; deploy safe temporary injection protections; confirm data exposure assumptions.	changes, monitoring evidence, validated loss assumptions.
Short term	Days 31–90	Deploy and tune API gateway, WAF and MFA/session controls; conduct staged rollout and independent retesting.	Configuration evidence, test results, tuning records, residual-risk sign-off.
Long term	Days 91–365	Continuous monitoring, quarterly control reviews, API inventory, secure SDLC gates, annual scenario refresh and independent assurance.	Quarterly KPI/KRI reporting, retest evidence, updated risk register.

The dates and sequencing are proposed planning assumptions because the brief supplies no implementation calendar, budget cap or delivery constraints.

8. Limitations and management decisions

The model is limited by the absence of a defined probability horizon, frequency data, confidence intervals, loss distributions, detailed incident-cost components, control deployment dependencies and a discount rate. The annual-probability interpretation should be reviewed with the risk owner. Management should confirm the database cost-per-record basis and WAF traffic coverage before relying on the financial comparison. The control effectiveness percentages are accepted as supplied scenario inputs and require validation through testing.

Prepared by: Hilda Odein Joshua-Jack | Registration number: C11/26/CGRCE/17247